

Les cinq recommandations sur les règles de gestion à mettre en place pour assurer la conformité RGPD des données du CRM

1) Définir une politique de conservation limitée

Règle RGPD associée : **Règle n°5 : Conservation limitée**

- Définir des durées de conservation précises :
 - Données de prospects (devis non converti) → suppression après 2 ans d'inactivité.
 - Données clients actifs → conservation pendant la durée du contrat + 5 ans (obligations légales).
- Mettre en place un mécanisme d'anonymisation ou de suppression automatique des données à l'expiration des délais.

Objectif : réduire le risque de conservation excessive et garantir la conformité au principe de limitation de durée.

2) Minimiser la collecte des données

Règle RGPD associée : **Règle n°3 : Minimisation des données**

- Supprimer les variables identifiantes dans les exports utilisés à des fins d'analyse commerciale (ex. : *nom, adresse, email*).
- **Anonymiser** ou pseudonymiser les données avant tout traitement statistique.
- Revoir les formulaires de collecte pour ne demander que les données strictement nécessaires à l'établissement d'un devis ou d'un contrat.
- Réduire la granularité des informations collectées (ex. : indiquer l'âge au lieu de la date de naissance exacte si cela suffit).

Objectif : permettre aux équipes commerciales de travailler efficacement sans manipuler de données personnelles ou sensibles, tout en respectant le RGPD.

3) Renforcer la sécurisation et la confidentialité des données

Règles RGPD associées : **Règle n°6 : Obligation de sécurité** et **Règle n°4 : Protection des données sensibles**

- Gérer les droits d'accès selon les rôles (ex. : commerciaux, administrateurs, DPO).
- Mettre en place le chiffrement des données sensibles et la journalisation des accès au CRM.
- Effectuer des sauvegardes régulières et contrôler les exportations de données.
- Interdire la collecte de données sensibles sauf si elle est légalement obligatoire (ex. : numéro de sécurité sociale).

Objectif : prévenir tout accès non autorisé et garantir la confidentialité et l'intégrité des données personnelles.

4) Gérer efficacement les droits des personnes

Règles RGPD associées : **Règle n°7** : Transparence et **Règle n°8** : Droits des personnes

- Informer clairement les personnes concernées de l'utilisation de leurs données et des moyens d'exercer leurs droits (ex. : finalité du traitement, durée de conservation, base légale, etc.).
- Mettre en place un canal unique pour recevoir les demandes d'accès, de rectification ou de suppression, par exemple, un formulaire RGPD intégré au site internet.
- Établir une procédure interne permettant de traiter chaque demande sous 30 jours maximum.

Objectif : renforcer la transparence et démontrer la conformité de l'entreprise vis-à-vis de la CNIL.

5) Garantir la légalité et la finalité des traitements de données

Règles RGPD associées : Règle n°1 : Légalité du traitement et Règle n°2 : Finalité

- Documenter la finalité de chaque traitement (ex. : gestion client, élaboration d'un devis, suivi commercial).
- Justifier la base légale pour chaque type de donnée :
 - Données nécessaires à un devis → mesure précontractuelle (pas de consentement requis).
 - Données marketing (email, usage du véhicule, etc.) → consentement explicite obligatoire.
- Interdire toute réutilisation des données à d'autres fins, notamment à des fins de profilage sans consentement.
- Créer une cartographie des données précisant : champ → finalité → base légale → durée de conservation.

Objectif : garantir que chaque donnée dispose d'une base légale claire et d'une finalité déterminée, explicite et légitime.